Enterprise Security Requirements
Version 3.2 - applies to all enterprise customer deployments.

Identity and access
Enterprise customers must enforce single sign-on (SSO) through SAML 2.0 or OpenID Connect. Multi-factor authentication (MFA) is required for every administrator account and for all access to production data.
Access reviews run every quarter; unused accounts are disabled after 30 days.

Data protection
Customer data must be encrypted at rest with AES-256 and in transit with TLS 1.2 or later. Encryption keys are managed in a dedicated KMS and are rotated every 90 days. Backups are encrypted and restore-tested monthly.

Data residency
Enterprise customers in the European Union keep primary data in EU regions.

Monitoring and audit
Audit logs are retained for 365 days and exported weekly to the customer SIEM.
Security incidents affecting customer data are reported within 24 hours.

Vendor and penetration testing
An independent penetration test is performed annually and after major releases.
Critical findings are remediated within 15 days.